

NEXHIRE

Quality, Delivery, Governance and Maintenance Manual

Testing, Risk, DevOps, Team Governance, Roadmap, AI Rules and Rebuild Guidance

Volume 4 of 4 | Version 3.0 | Team ALPHA | 5 August 2026

Enterprise Second-Brain Edition - Controlled Source of Truth

Document Control and Version History

Field	Value
Product	NexHire Smart Recruitment Matching Platform
Document Set	Enterprise Documentation and Second Brain v3.0
Owner	Kogul / Team ALPHA
Classification	Project Internal / Academic Submission / Client-Ready
Canonical Product Baseline	Second Brain Final Pack v2.0
Implementation Overlay	Master Documentation and Team Handover Pack
Review Rule	Changes require an approved decision record and traceability update

Version	Date	Status	Summary
1.0	4 Aug 2026	Historical	Original source documentation baseline
2.0	5 Aug 2026	Validated Source	Second Brain canonical pack and validated prototype
3.0	5 Aug 2026	Current Controlled Edition	Unified enterprise documentation with conflicts resolved through phase boundaries

Authoritative interpretation rule

Core Release v1.0 follows the trust-first, explainable matching, duplicate-safe application and consent-gated contact scope of the validated Second Brain pack. Interview, Offer, Talent Pool and Complaint capabilities from the implementation overlay are retained as Phase 2 extensions, not silently mixed into Core Release v1.0.

Table of Contents

39	Testing Strategy
40	Test Cases and Traceability
41	Quality Gates and Acceptance
42	Risk Analysis
43	DevOps and Release Management
44	Team Governance and Module Ownership
45	Maintenance and Change Management
46	AI Second-Brain Operating Rules
47	Future Enhancements and Roadmap
48	Conclusion and Final Review
49	References and Appendices

39. Testing Strategy

39.1 Test Levels

Level	Scope
Unit	Domain policies, score components, transition matrices, validators, masking and mapping.
Integration	EF constraints, transactions, outbox, Identity, file metadata and API handlers.
Contract	OpenAPI schema, response/error compatibility and frontend adapter.
Security	Role/resource/state authorization, token lifecycle, file access, PII and rate limits.
End-to-End	Role journeys from registration to contact decision and administration.
Performance	Search, ranking, match, dashboards, exports and concurrency hotspots.
Accessibility	Keyboard, semantics, focus, labels, status and responsive interaction.
Recovery	Backup restore, outbox reconciliation and worker restart.

39.2 Test Data Strategy

- Synthetic accounts for each role and state.
- Verified and rejected companies.
- Draft, active, closed, expired and moderated vacancies.
- Candidates with complete, partial and missing evidence.
- Golden RM-1.0 score fixtures.
- Duplicate/concurrent application attempts.
- Pending, accepted, declined and expired contact requests.
- Clean, invalid, oversized and malicious-simulation file fixtures.

40. Test Cases and Traceability

ID	Scenario	Expected Result
TC-001	Register valid Job Seeker	201 and account/profile context created
TC-002	Duplicate email registration	409; no duplicate identity
TC-003	Login suspended account	401/403 policy outcome; no session
TC-004	Refresh token rotation replay	Old token rejected and session risk recorded
TC-005	Candidate profile stale If-Match	412; no overwrite
TC-006	Duplicate candidate skill	409; one CandidateSkill
TC-007	Upload invalid CV type	415; no active private file
TC-008	Upload oversized CV	413
TC-009	Stream unscanned CV	423
TC-010	Public search unverified company vacancy	Vacancy absent
TC-011	RM-1.0 golden fixture	Exact components and total
TC-012	Preferred skill difference in Core	No score change
TC-013	Concurrent duplicate apply	One Application only
TC-014	Idempotent retry apply	Same outcome/reference
TC-015	Invalid application status transition	409/422; no history append
TC-016	Employer accesses another company application	404/403; no data
TC-017	Contact details before acceptance	Not returned
TC-018	Accept expired contact request	409/412; no detail release
TC-019	Admin attempts candidate score override	No endpoint/policy
TC-020	Suspend account	Sessions revoked; audit event
TC-021	CSV formula injection value	Safely escaped
TC-022	Worker duplicate expiry processing	One final state/history effect

ID	Scenario	Expected Result
TC-023	Restore backup	Integrity checks pass
TC-024	Keyboard-only critical journey	No keyboard trap; visible focus

40.1 Traceability Model

Each requirement is connected to use case, module, API, table/policy and test. The machine-readable traceability file delivered with this pack provides an initial mapping and must be updated with repository test identifiers.

41. Quality Gates and Acceptance

Gate	Pass Criteria
Product Consistency	No conflicting active scope, status or matching rule.
Build	All projects compile; migrations and frontend static checks pass.
Contract	OpenAPI generated and reviewed; no undocumented breaking changes.
Business Invariants	Golden matching, duplicate apply, consent and trust predicates pass.
Security	Role/resource/file/contact tests pass; no high critical finding.
Data	Constraints, indexes and migration rollback/forward reviewed.
UX	Critical journeys have loading/empty/error states and accessibility checks.
Operations	Health, logs, metrics, backup and recovery evidence available.
Documentation	Change log, decisions, API, data and tests synchronized.

41.1 Definition of Done

1. Requirement and rule identified.
2. Design and contract approved.
3. Implementation follows module boundary.
4. Unit/integration/security tests pass.
5. Frontend uses exact contract.
6. Telemetry and safe errors exist.
7. Documentation and traceability updated.
8. Pull request reviewed and merged.

42. Risk Analysis

ID	Risk	Severity	Mitigation
R-01	Scope drift between Core Release and Phase 2	Critical	Use phase boundaries and approved change records.
R-02	Matching formula divergence	Critical	Freeze RM-1.0 machine-readable contract and golden tests.
R-03	API/documentation drift	High	Publish OpenAPI and run CI contract checks.
R-04	PII/contact leakage	Critical	Resource authorization, masking, consent-state checks and audit.
R-05	Malicious file upload	High	Quarantine, MIME/signature validation, malware scan and private storage.
R-06	Duplicate application under concurrency	High	Unique index, transaction and Idempotency-Key.
R-07	Unapproved admin score manipulation	High	No candidate-score mutation endpoint; immutable rule

ID	Risk	Severity	Mitigation
			versions.
R-08	Prototype treated as production evidence	High	Separate demonstration evidence from production verification.
R-09	Team merge conflicts	Medium	Module ownership, shared-file approval and pull-request workflow.
R-10	Retention/legal ambiguity	High	Approve retention/deletion policy before production launch.
R-11	Over-engineered MVP deployment	Medium	Use a simple MVP topology while preserving production target architecture.
R-12	Insufficient automated tests	High	Trace every requirement to unit, integration, security and E2E tests.

42.1 Risk Review Cadence

The product owner and technical lead review Critical/High risks before each release. Each risk has owner, trigger, mitigation evidence and residual assessment. Scope and matching conflicts are release blockers, not documentation notes.

43. DevOps and Release Management

43.1 Git Workflow

Branch	Purpose
main	Stable release/submission code only.
develop	Integrated tested development baseline.
feature/auth	Identity and access.
feature/jobseeker	Candidate profile, skills and CV.
feature/company	Company and vacancy lifecycle.
feature/matching	Applications and RM-1.0.
feature/contact	Contact consent and employer review; Core Release.
feature/admin	Verification, moderation, users, reports and audit.
feature/interview	Phase 2 only after approved change.

43.2 CI/CD Pipeline

9. Restore and compile.
10. Static analysis, formatting and dependency scan.
11. Unit tests and coverage threshold.
12. Integration tests with ephemeral SQL/storage.
13. Generate and diff OpenAPI.
14. Build frontend and run accessibility/static checks.
15. Build container/package and create SBOM.
16. Deploy to staging.
17. Run E2E, security smoke and migration checks.
18. Manual approval and production deployment.
19. Post-deployment health and rollback observation.

43.3 Release Artifacts

- Application packages/images and checksums.

- Database migration bundle and rollback notes.
- OpenAPI contract.
- Documentation version and machine-readable contracts.
- Test and security reports.
- SBOM and dependency list.
- Deployment configuration manifest excluding secrets.

44. Team Governance and Module Ownership

Team Stream	Owned Core Modules	Dependencies
Member 1 - Auth	M01	Provides user/role/account-state contract to all.
Member 2 - Job Seeker	M02, M03, M04	Feeds matching and private evidence.
Member 3 - Company/Vacancy	M05, M06	Feeds search, matching and applications.
Member 4 - Matching/Application	M08, M09, M10, M11	Depends on candidate and vacancy contracts.
Member 5 - Consent / Phase 2	M12 for Core; Interview/Offer only after CR	Depends on eligible application state.
Member 6 - Admin/QA	M13, M14, M15, M16 and final QA	Consumes events/data across modules.

44.1 Shared File Rule

Program startup, DbContext, shared enums, common error contracts, migration baseline and cross-module interfaces are controlled shared assets. A member proposes the change; the technical lead reviews impact; all dependent branches rebase/pull after merge.

44.2 Integration Order

20. Identity baseline.
21. Candidate evidence and company/vacancy contracts in parallel.
22. Matching and application.
23. Employer review, status and consent contact.
24. Notifications, reports, governance and lifecycle worker.
25. Phase 2 modules only after Core quality gate.

45. Maintenance and Change Management

45.1 Change Types

Type	Examples	Approval
Editorial	Clarification without meaning change	Documentation owner
Implementation Mapping	Route/property rename preserving contract	Technical lead
Business Rule	Application uniqueness, trust predicate, status transition	Product owner + architect
Matching Rule	Weights/factors/rounding	Product owner + fairness/security review
Scope	Interview/Offer/Talent Pool activation	Product owner + team impact review
Breaking API/Data	Contract or schema incompatibility	Architecture review and version/migration plan

45.2 Decision Records Required

- Context and problem
- Decision and status

- Alternatives considered
- Business, security, data, API, UI and test impact
- Migration/backward compatibility
- Owner and approval date

45.3 Maintenance Procedures

- Monthly dependency/security review during active development.
- Database index/query review based on telemetry.
- Quarterly restore test for production target.
- Audit and retention verification.
- Documentation drift check in CI.
- Prototype updated only after source-of-truth contracts.

46. AI Second-Brain Operating Rules

AI execution order

Read Product Constitution -> Release Scope -> Business Rules -> Statuses -> Architecture -> API/Data Contracts -> Module Ownership -> Tests -> Current Repository Mapping. Do not generate code before resolving contradictions.

26. Preserve role separation, trust predicate, explainability, application integrity and consent meaning.
27. Do not merge Core and Phase 2 scopes without an approved change record.
28. Use RM-1.0 for Core; label every future rule proposal with a new version.
29. Inspect actual entities and OpenAPI before using property or route names.
30. Never guess a missing relationship, enum, retention rule or external integration.
31. When a source gap exists, mark it as OPEN DECISION and request approval.
32. Do not remove an approved module merely because implementation is incomplete.
33. Do not treat prototype client-side checks as server security evidence.
34. Generate tests and traceability with every consequential change.
35. Update machine-readable contracts and version history.

46.1 AI Pre-Implementation Response Template

Before changing code, the AI must state: (A) module and release phase; (B) preserved business rules; (C) contracts/entities inspected; (D) proposed files; (E) migration/security impact; and (F) tests proving completion.

47. Future Enhancements and Roadmap

Release	Capabilities	Entry Criteria
Core v1.0	Trust, evidence, RM-1.0, applications, status, consent contact, governance	All Core quality gates pass.
Phase 2.1	Interview scheduling/evaluation	Approved CR, time-zone/calendar/security and state design.
Phase 2.2	Offer lifecycle	Approved compensation, expiry, legal and audit rules.
Phase 2.3	Talent Pool and Complaint Cases	Consent/retention and case SLA approved.
Phase 3	RM-2.0 experimentation and advanced analytics	Fairness review, versioning, A/B governance and replay.

Release	Capabilities	Entry Criteria
Enterprise Scale	Optional service extraction, federation, multi-region strategy	Measured demand and operational maturity.

47.1 AI and Automation Opportunities

- Skill alias recommendation under administrator approval.
- CV structure assistance without hidden employability scoring.
- Vacancy quality linting before moderation.
- Operational anomaly detection over non-sensitive metrics.
- Automated documentation and contract drift checks.
- No autonomous final hiring or protected-characteristic inference.

48. Conclusion and Final Quality Review

This four-volume documentation set provides a unified enterprise foundation for academic submission, client review, team implementation and future maintenance. It resolves source contradictions through explicit release boundaries, freezes Core RM-1.0, preserves the extended product roadmap and establishes traceability, security and change-governance rules.

Final Review Item	Status
Requested sections included across four volumes	PASS
Duplicate active business rules removed	PASS
Source conflicts explicitly resolved/labeled	PASS
Consistent terminology and release phases	PASS
Architecture, API, data, UX and tests aligned	PASS
No unapproved project detail presented as fact	PASS - open decisions are labeled
Academic/client/developer readiness	PASS subject to repository/OpenAPI reconciliation
Machine-readable contracts provided	PASS

49. References and Appendices

- All source documents listed in Volume 1 References.
- OWASP-style secure design principles are reflected without claiming an external certification.
- Exact technology versions, retention values, jurisdiction and production RPO/RTO remain controlled release decisions.

Appendix D - Rebuild Checklist

36. Read all volumes and machine-readable contracts.
37. Obtain current approved decisions and repository mapping.
38. Create solution/folder structure and module boundaries.
39. Implement identity and account-state baseline.
40. Implement candidate/company evidence and trust.
41. Implement canonical skills, vacancies and RM-1.0 golden tests.
42. Implement duplicate-safe applications and state history.
43. Implement consent contact, notifications, audit and worker.
44. Implement admin governance and reports.
45. Run all quality gates before Phase 2.

49.1 v3.1 Amendment - Company Verification Quality Gates

Area	v3.1 Approved Rule
Functional gate	All employer and administrator verification screens, statuses, decisions, reasons, notifications and publishing restrictions pass end-to-end tests.
Security gate	Unauthorized document access, insecure file types, oversized files, malware test samples, IDOR attempts and audit omissions are blocked.
UX gate	Employers can understand what is missing, what is under review, why a decision occurred and how to correct it without support intervention.
Data gate	Only one active review is allowed per company; decision history is preserved; public trust projection reflects the current authoritative state.
Release gate	The prototype, functional specification, API catalogue, statuses, module ownership and test cases must all contain the same state vocabulary.

This amendment is authoritative for Company Verification. Where an earlier summary is less detailed, this amendment and Volume 05 provide the complete implementation and UX contract.